

개인정보 보호 자체점검 체크리스트(예시)

점검항목	점검지표	세부내용
1.개인정보의 수집	1.1 개인정보수집	○ 법률 및 법령 등에서 정한 소관업무에 따라 개인정보를 수집하고 있는가? ○ 필수고지사항을 정보주체에게 고지하고 동의를 받고 있는가?
	1.2 민감정보 /고유식별정보 수집	○ 법령 근거에 따라 민감정보를 수집하고 있는가? ○ (법령 근거가 없는 경우) 민감정보 수집시 일반 개인정보수집과 별도로 동의를 받고 있는가?
	1.3 주민등록번호 처리제한	○ 법령에 근거하여 주민등록번호를 수집하고 있는가?
	1.4 만14세미만아동의개인정보수집	○ 만 14세 미만 아동의 개인정보를 수집하는 경우 법정대리인의 동의를 받고 있는가?
	1.5 개인정보처리방침	○ 개인정보 처리방침을 현행화하고 있는가?
2. 개인정보의 제3자 제공	2.1 목적 외 개인정보 제공	○ 법률 및 법령 등에서 정한 소관업무(보호위원회 심의의결을 받은 경우)에 따라 개인정보를 제공하고 있는가? ○ (법령 근거가 없는 경우)정보주체에게 필수 고지사항에 대해 별도 동의를 받고 개인정보를 제공하고 있는가?
	2.2 목적 외 제공 시 안전 조치	○ 개인정보 목적 제공 시 암호화 전송, 목적 달성 시 파기 안내 등 안전조치를 하고 있는가?
	2.3 목적 외 제공 시 공개	○ 개인정보 목적 제공 시 홈페이지에 제공사항을 공개하고 있는가?
	2.4 제3자 제공 관리대장	○ 목적 외 제공 내역을 제3자 제공 대장 내 기록하고 있는가?
3. 개인정보 보관	3.1 수기 문서 보관 시	○ 잠금장치가 있는 캐비닛에 서류를 보관하는가?
	3.2 업무용 PC 내 보관 시	○ 개인정보 보관 시 암호화 등 보안조치를 하는가? ○ 불필요한 개인정보는 삭제하였는가
	3.3 DB 내 보관 시	○ 개인정보는 안전한 알고리즘으로 암호화하고 있는가? ○ DB내 비밀번호 보관시 안전한 알고리즘으로 암호화하고 있는가?
4. 개인정보 파기	4.1 보유기간 경과시 개인정보 파기	○ 보유기간 경과 시 지체없이 개인정보를 파기하고 있는가?
5. 개인정보 위탁	5.1 개인정보 위탁계약서 작성	○ 표준위탁 계약서를 준용하는가?
	5.2 수탁사교육	○ 연 1회 이상 수탁사 교육을 수행하고 있는가?
	5.3 관리감독 이행 여부	○ 연 1회 이상 수탁사 관리감독을 수행하고 있는가?
6. 취급자접속기록	6.1 접속기록 보관	○ 고유식별정보, 민감정보 수집시 취급자 접속기록이 2년 이상 보관되고 있는가? ○ 5만명 이상의 개인정보 보유시 취급자 접속기록이 2년 이상 보관되고 있는가? ○ 개인정보보유시 1년이상 보관되고 있는가?
	6.2 접속기록 점검	○ 월1회 이상 접속기록을 점검하고 있는가? ○ 접속기록 점검시 필수항목(접속계정, 접속일시, 접속지정보, 정보주체, 수행업무)를 포함하였는가 ○ 개인정보를 다운로드하는 경우 그 사유를 확인하고 있는가?
7. 시스템접근권한	7.1 접근권한 기록 3년 보관	○ 시스템 취급자 계정 접근권한 부여/정정/말소 기록은 3년간 보관되고 있는가?
	7.2 접근권한 현행화	○ 인사이동, 퇴직 등 발생 시 지체없이 계정 접근권한을 변경/말소 하고 있는가?
	7.3 접근권한 최소화	○ 업무에 필요한 최소한의 권한만 부여되고 있는가?
	7.4 1인 1계정 사용	○ 취급자계정을 1인1계정 사용하고 있는가?(1인 다계정, 공용아이디 사용 등 확인)